

Отчёт по анализу Android-приложения

SI - Betting tips — Sports Insider App — com.sports.insider (версия 1.2.44.123)

Разобраны: харк и арк-сплиты, meta.json, domain_checks, AndroidManifest.xml, strings.xml, network_security_config и decompiled/sources — запуск (MyApp, SplashActivity, MainActivity, онбординг), сетевой слой (Retrofit/OkHttp, sport-insider.club), встроенные окна сайта (ViewPagerFragment, ViewPagerEventFragment, ViewCloudFragment), каналы связи страницы с приложением, сохранённые настройки и подключённые сервисы (AppsFlyer, AppMetrica, LogRocket, Firebase, Sentry).

SDK / стек

Параметр	Значение
Название приложения	SI - Betting tips (Sports insider)
Android Gradle Plugin	8.13.2
minSdk	23
targetSdk	36
Kotlin	да, 2.2.21
Web View	да
Custom Tabs	нет
Рекламные сети	нет
Аналитика	AppsFlyer 6.17.5, AppMetrica (Yandex) 8.0.0 — включая модули analytics-screenshot, analytics-identifiers, analytics-id-sync, analytics-location, analytics-billing и analytics-ad-revenue, LogRocket 1.57.4 (запись сессий), Sentry 8.30.0 (sentry-android-replay, sentry-android-fragment, sentry-android-navigation, sentry-okhttp, sentry-android-ndk; DSN sentry.sport-insights.com, send-default-pii = true), Firebase Analytics 23.0.0 / Google Analytics for Firebase (play-services-measurement 23.0.0), Firebase Cloud Messaging 25.0.1, Firebase Remote Config 23.0.1 + Firebase A/B Testing (abt), Firebase Installations, Firebase datatransport, Google Play Install Referrer 2.2, Xiaomi/MIUI home referrer 1.0.0.7, Google Advertising ID (play-services-ads-identifier 18.2.0), Google App Set ID, собственная аналитика приложения (v10/metrics, v10/pushes, v10/live/view, v10/advert/{id}/view и v10/advert/{id}/click)
Permissions	android.permission.INTERNET, android.permission.ACCESS_WIFI_STATE, android.permission.ACCESS_NETWORK_STATE, android.permission.VIBRATE, android.permission.ACCESS_DOWNLOAD_MANAGER, android.permission.CAMERA, android.permission.READ_EXTERNAL_STORAGE, android.permission.READ_MEDIA_VISUAL_USER_SELECTED, android.permission.POST_NOTIFICATIONS, android.permission.WRITE_EXTERNAL_STORAGE, android.permission.INSTALL_PACKAGES, android.permission.WAKE_LOCK, android.permission.ACCESS_AD SERVICES_ATTRIBUTION, android.permission.ACCESS_AD SERVICES_AD_ID, android.permission.USE_BIOMETRIC, android.permission.USE_FINGERPRINT, android.permission.RECEIVE_BOOT_COMPLETED, android.permission.FOREGROUND_SERVICE, com.android.vending.BILLING, com.google.android.providers.gsf.permission.READ_GSERVICES, com.google.android.finsky.permission.BIND_GET_INSTALL_REFERRER_SERVICE, com.google.android.gms.permission.AD_ID, com.google.android.c2dm.permission.RECEIVE, com.samsung.android.mapsagent.permission.READ_APP_INFO, com.huawei.appmarket.service.commondata.permission.GET_COMMON_DATA, com.sports.insider.DYNAMIC_RECEIVER_NOT_EXPORTED_PERMISSION

Параметр	Значение
Libraries	androidx.appcompat 1.7.1, androidx.activity 1.12.2, androidx.fragment, androidx.core / core-ktx 1.17.0, androidx.core.splashscreen 1.2.0, androidx.constraintlayout 2.2.1, androidx.coordinatorlayout, androidx.recyclerview, androidx.viewpager / viewpager2, androidx.cardview, androidx.drawerlayout, androidx.swiperefreshlayout, androidx.biometric 1.1.0, androidx.credentials (+ play-services-auth), androidx.datastore (preferences), androidx.room 2.8.4, androidx.sqlite, androidx.work 2.11.0, androidx.lifecycle, androidx.navigation, androidx.startup, androidx.emoji2, androidx.exifinterface, androidx.profileinstaller, androidx.privacysandbox.ads, androidx.print, androidx.databinding / viewbinding, com.google.android.material, Kotlin stdlib 2.2.21, kotlinx.coroutines 1.10.2, OkHttp3, Okio, Retrofit, Gson, Coil (загрузка изображений), Koin (внедрение зависимостей), Google Play Billing 7.1.1, Google Play app-update, Google Play Integrity, Google Play Services (ads-identifier 18.2.0, auth, base / basement 18.10.0, appset, cloud-messaging, measurement, location, tasks, fido, identity-credentials), Firebase (analytics, messaging, remote-config, installations, datatransport, common), AppsFlyer SDK, AppMetrica SDK (+ модули ad-revenue admob / applovin / fyber / ironsource), LogRocket Android SDK, Sentry Android SDK, системный android.webkit.WebView
Подозрительные домены	insider.sports.com, sport-insider.club
SharedPreferences	два файла настроек — «user» и «settings». Хранят: рекламный номер устройства (gaid) и время его получения (advertising_id_saved_at), язык интерфейса (language, langWorkKey), push-токен Firebase (fbToken, fbTokenLastTime), флаг первого запуска (firstStart), готовую HTML-страницу букмекерского «персонального бонуса» (rate) и время следующей проверки этой страницы (rating), готовую HTML-страницу объявления (announcement) вместе с announcementId, announcementIdCreate, announcementIsRead, а также pressed_close, push_on_channel / push_on_channel_live_passed, alternativePaymentPriority, DEPRECATED_VERSION_CODE, ExpiredForecastsOrder, CPEnableSupportParams, idPrediction, notifyId; отдельно кэш удалённого конфига Firebase (rc_live_passage, rc_roi_live, rc_premium_*, rc_express_*, rc_diamond_*, rc_sku_json, rc_version_deprecated, min_odds_premium / min_odds_express, enable_clear_data, enable_expedited)
Есть ли клоака	да
Подозрительные слова	betting, Sports_betting, betting_training, Betting_strategies, Corridor_betting, hand_betting, Value_betting, bookmaker, open_bookmaker, recommendation_how_to_register_in_bookmaker_office, bonus, Bonuses, Get_bonus, get_bonus, personal_bonus, onPersonalBonus, onMyBonuses, DelayStavkaBonus («Place a bet and get a bonus»), DelayStavkaBonus1 («Get bonus from partners»), partners, offer, offer_is_limited, offerId / offerIdStrike, advert, urlBet, imageBet, v10/advert/{id}/click, v10/advert/{id}/view, ResponsibleGaming, gaid, region, rate, rating, openUrlByBrowser, AndroidMainInterface, insightsapp://bonuses

Проверка подозрительных доменов

Данные ниже взяты как есть из готовых проверок пайплайна (domain_checks.json / domain_checks.md): сводка VirusTotal, полный список Security vendors' analysis и три дополнительных пункта в конце.

Проверка домена: insider.sports.com

Параметр / движок	Значение / вердикт
Домен	insider.sports.com
VirusTotal URL	https://www.virustotal.com/gui/domain/insider.sports.com
Детекции	0/91 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
Abusix	Clean
Acronis	Clean

Параметр / движок	Значение / вердикт
ADMINUSLabs	Clean
AlienVault	Clean
alphaMountain.ai	Clean
Antiy-AVL	Clean
Bfore.Ai PreCrime	Clean
BitDefender	Clean
Blueliv	Clean
Certego	Clean
Chong Lua Dao	Clean
CINS Army	Clean
CMC Threat Intelligence	Clean
CRDF	Clean
Cyble	Clean
CyRadar	Clean
desenmascara.me	Clean
DNS8	Clean
Dr.Web	Clean
EmergingThreats	Clean
Emsisoft	Clean
ESET	Clean
ESTsecurity	Clean
Forcepoint ThreatSeeker	Clean
Fortinet	Clean
G-Data	Clean
Google Safe Browsing	Clean
GreenSnow	Clean
Heimdal Security	Clean
IPsum	Clean
Juniper Networks	Clean
Kaspersky	Clean
Lionic	Clean
Malwared	Clean
MalwarePatrol	Clean
OpenPhish	Clean
Phishing Database	Clean
Phishtank	Clean
PREBYTES	Clean
Quick Heal	Clean
Quttera	Clean
Scantitan	Clean
SCUMWARE.org	Clean
Seclookup	Clean
SecureBrain	Clean

Параметр / движок	Значение / вердикт
Snort IP sample list	Clean
Sophos	Clean
StopForumSpam	Clean
Sucuri SiteCheck	Clean
ThreatHive	Clean
URLhaus	Clean
Viettel Threat Intelligence	Clean
ViriBack	Clean
VX Vault	Clean
Webroot	Clean
Xcitium Verdict Cloud	Clean
Yandex Safebrowsing	Clean
ZeroCERT	Clean
0xSI_f33d	Unrated
AILabs (MONITORAPP)	Unrated
AlphaSOC	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bkav	Unrated
ChainPatrol	Unrated
Cluster25	Unrated
Criminal IP	Unrated
CSIS Security Group	Unrated
CTX AI	Unrated
Cyan	Unrated
Ermes	Unrated
Fortra	Unrated
GCP Abuse Intelligence	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Hunt.io Intelligence	Unrated
LevelBlue	Unrated
Lumu	Unrated
MalwareURL	Unrated
Mimecast	Unrated
Netcraft	Unrated
PhishFort	Unrated
PrecisionSec	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
SOCRadar	Unrated

Параметр / движок	Значение / вердикт
URLQuery	Unrated
VIPRE	Unrated
ZeroFox	Unrated
Куда редиректит	нет (DNS не резолвится)
Что выводит (кратко)	нет (DNS не резолвится)
Где припаркован	регистратор/whois связан с парковкой: godaddy

Проверка домена: sport-insider.club

Параметр / движок	Значение / вердикт
Домен	sport-insider.club
VirusTotal URL	https://www.virustotal.com/gui/domain/sport-insider.club
Детекции	0/91 (malicious=0, suspicious=0)
Security vendors' analysis	ниже построчно, как на VirusTotal
Abusix	Clean
Acronis	Clean
ADMINUSLabs	Clean
AILabs (MONITORAPP)	Clean
AlienVault	Clean
Antiy-AVL	Clean
BitDefender	Clean
Blueliv	Clean
Certego	Clean
Chong Lua Dao	Clean
CINS Army	Clean
CMC Threat Intelligence	Clean
CRDF	Clean
Cyble	Clean
CyRadar	Clean
desenmascara.me	Clean
DNS8	Clean
Dr.Web	Clean
EmergingThreats	Clean
Emsisoft	Clean
ESET	Clean
ESTsecurity	Clean
Forcepoint ThreatSeeker	Clean
Fortinet	Clean
G-Data	Clean
Google Safe Browsing	Clean
GreenSnow	Clean
Heimdal Security	Clean
IPsum	Clean

Параметр / движок	Значение / вердикт
Juniper Networks	Clean
Kaspersky	Clean
Lionic	Clean
Malwared	Clean
MalwarePatrol	Clean
Netcraft	Clean
OpenPhish	Clean
Phishing Database	Clean
Phishtank	Clean
PREBYTES	Clean
Quick Heal	Clean
Quttera	Clean
Scantitan	Clean
SCUMWARE.org	Clean
Seclookup	Clean
Sophos	Clean
StopForumSpam	Clean
Sucuri SiteCheck	Clean
ThreatHive	Clean
URLhaus	Clean
Viettel Threat Intelligence	Clean
ViriBack	Clean
VX Vault	Clean
Webroot	Clean
Xcitium Verdict Cloud	Clean
Yandex Safebrowsing	Clean
ZeroCERT	Clean
0xSI_f33d	Unrated
alphaMountain.ai	Unrated
AlphaSOC	Unrated
ArcSight Threat Intelligence	Unrated
AutoShun	Unrated
Axur	Unrated
Bfore.Ai PreCrime	Unrated
Bkav	Unrated
ChainPatrol	Unrated
Cluster25	Unrated
Criminal IP	Unrated
CSIS Security Group	Unrated
CTX AI	Unrated
Cyan	Unrated
Ermes	Unrated
Fortra	Unrated

Параметр / движок	Значение / вердикт
GCP Abuse Intelligence	Unrated
GreyNoise	Unrated
Gridinsoft	Unrated
Guardpot	Unrated
Hunt.io Intelligence	Unrated
LevelBlue	Unrated
Lumu	Unrated
MalwareURL	Unrated
Mimecast	Unrated
PhishFort	Unrated
PrecisionSec	Unrated
SafeToOpen	Unrated
Sansec eComscan	Unrated
SecureBrain	Unrated
Snort IP sample list	Unrated
SOCRadar	Unrated
URLQuery	Unrated
VIPRE	Unrated
ZeroFox	Unrated
Куда редиректит	нет (без редиректа)
Что выводит (кратко)	title: Not Found. Not Found 404 Not Found
Где припаркован	регистратор/whois связан с парковкой: godaddy

Какие данные собираются

- постоянный номер телефона → служебный номер устройства, который Android выдаёт приложениям (в запросе он называется `device_id`). По нему сервер узнаёт конкретный телефон при каждом обращении, даже если человек ничего не вводил.
- прежний номер телефона → если служебный номер устройства поменялся, старое значение тоже отправляется (`device_id_old`), чтобы сервер связал нового посетителя со старой историей этого же человека.
- рекламный номер устройства → отдельный номер телефона для рекламы (`gaid`). Именно по нему рекламные партнёры отличают одно устройство от другого и считают, кто откуда пришёл.
- номер устройства в системе AppMetrica → собственный опознавательный номер, который телефону присваивает счётчик посещаемости Яндекса (`appmetrica_device_id`).
- номер устройства в системе AppsFlyer → опознавательный номер из системы учёта рекламных переходов (`appsflyer_id`); по нему видно, по какой именно рекламе человек установил приложение.
- ключ для присылки уведомлений → адрес телефона в службе уведомлений Google (`firebase_token`). С ним сервер может в любой момент прислать человеку сообщение прямо на экран.
- вид телефона и магазина → признак «`android_google`» (поле `os`) — то есть Android-телефон из Google Play.
- версия приложения → текстовая версия 1.2.44.123 (`version_client`) и её внутренний номер 123 (`version_code`).

- язык телефона → на каком языке настроен телефон. Приложение приводит его к «ru» или «en» и отправляет в заголовке запроса вместе с полным обозначением языка и страны — именно по языку решается, показывать ли человеку страницу букмекера.
- страна человека → название страны, взятое из настроек телефона; уходит в запрос отдельным полем «region» перед показом страницы букмекера.
- личный пропуск в приложении → личный ключ учётной записи (token), который выдаёт сам сервер и который подставляется в каждый запрос.
- марка и модель телефона → модель, производитель, название сборки и внутренние обозначения железа (MODEL, PRODUCT, HARDWARE, DISPLAY) — уходят в служебных сообщениях о работе приложения.
- версия Android → какая версия системы стоит на телефоне; отправляется вместе с данными о модели.
- часовой пояс и время → смещение часового пояса и точное время обращения — по ним видно, в каком примерно поясе находится человек.
- действия человека внутри приложения → названия событий, их значения и время (поля event, event_value, created_at) уходят пачками на собственный адрес приложения; отдельно уходит список полученных уведомлений и просмотренных сообщений.
- запись работы экрана → встроенная система LogRocket пишет, что происходит на экране и как человек нажимает, и отправляет это на свои адреса.
- сведения об ошибках вместе с личными данными → система отчётов об ошибках Sentry включена в режиме, при котором разрешено передавать личные сведения о пользователе и структуру экрана (send-default-pii = true, attach-view-hierarchy = true).

Как собираются

Сбор начинается сразу после заставки, на самом первом шаге знакомства приложения с телефоном, и человек об этом ничего не спрашивается. Служебный номер устройства приложение читает прямо из системных настроек Android, рекламный номер запрашивает у сервисов Google и кладёт себе в память на сутки, чтобы не дёргать систему каждый раз. Опознавательные номера из счётчиков Яндекса и AppsFlyer, а также ключ для уведомлений приложение получает у самих этих служб при запуске — все четыре запроса делаются одновременно, с ожиданием не дольше половины секунды, чтобы человек не заметил задержку. Язык и страну приложение берёт из настроек телефона, версию и модель — у самой системы. Никаких отдельных окон с просьбой разрешить это не показывается: с точки зрения человека просто идёт заставка, а затем открывается обычный экран с прогнозами. Отдельно, уже в фоне, работает служба записи происходящего на экране и служба отчётов об ошибках — они включаются в момент старта программы.

Куда отправляются

Основной адрес один и тот же для всех запросов: <https://sport-insider.club/api/> — он зашит прямо в код, запасных или собираемых по кусочкам адресов там нет. На него уходит и первое «знакомство» с телефоном (v10/user/identify), и запрос рекламных мест (v10/advert), и обе проверки страницы букмекера (v10/rating/exist и v10/rating), и статистика действий. Этот же адрес продублирован в настройках счётчика Яндекса и в отчётах об ошибках как «BASE_URL», а сами отчёты об ошибках уходят на отдельный адрес автора приложения — sentry.sport-insights.com. Записи того, что происходит на экране, уходят в службу LogRocket. Всё это происходит тихо, в фоне, без какого-либо экрана или подтверждения. Полученную от сервера страницу приложение сохраняет в собственную память телефона, чтобы потом показать её уже без интернета.

Как фильтруются пользователи

Первое сито стоит в самом приложении и работает по языку: перед тем как вообще обратиться к серверу за страницей букмекера, приложение сравнивает язык, который у него выбран, с

языком телефона, и если они не совпадают — сразу считает, что страницы нет, и никуда не ходит. Язык телефона при этом приводится всего к двум значениям: «ru» или «en», и это значение подставляется в каждый запрос. Второе сито — географическое: в запрос кладётся название страны человека, взятое из настроек телефона, и решение «есть для этой страны страница или нет» принимает уже сервер. Третье ограничение — по времени: результат проверки запоминается на десять минут, чтобы не спрашивать сервер слишком часто. Никаких списков стран, проверок на робота или на эмулятор внутри самого приложения нет — в коде видно только отправку признаков (язык, страна, номера устройства, версия), а окончательное решение, кому показать букмекерскую страницу, а кому оставить обычное приложение, принимает сервер по адресу `sport-insider.club`. От этого же ответа зависит и меню: пункт «Personal bonus» появляется в боковом меню только тогда, когда серверная проверка прошла успешно, иначе на его месте оказывается обычный «Избранное».

Что возвращается

Сервер отвечает двумя разными способами. На первую, короткую проверку он возвращает только числовой код: 200 означает «для этого человека страница есть», 404 — «страницы нет», 401 — «доступ закрыт». Если пришло «есть», приложение делает второй запрос и получает уже готовую веб-страницу целиком — не ссылку, а полный текст страницы, который сразу кладётся в память телефона под именем «rate». Похожим образом приходят и «объявления»: уведомление приносит номер объявления, приложение скачивает по нему готовую страницу и сохраняет её под именем «announcement». Отдельно есть ответ на запрос рекламных мест: там сервер присылает список готовых блоков с картинкой, внешней ссылкой и номером для каждого места в приложении (шапка, нижнее меню, экраны прогнозов, кнопка «Live», экран после оплаты). Если список пуст, блоки просто не появляются, и человек видит обычные экраны без рекламных вставок.

Как показывается оффер или белая версия

Когда сервер отдал страницу, она открывается внутри самого приложения, во встроенном окне сайта — отдельного браузера человек не видит, всё выглядит как обычный раздел программы. Попасть туда можно двумя путями: через пункт бокового меню «Personal bonus» или по служебной ссылке вида `insightsapp://bonuses`, которая может прийти, например, из уведомления. В момент открытия этого окна приложение само записывает себе событие «open_bookmaker» — то есть по коду прямо видно, что это страница букмекерской конторы, а не обычный раздел с прогнозами. Дальше любое нажатие на этой странице выводит человека наружу: приложение перехватывает переход и открывает адрес во внешнем браузере телефона. Более того, страница, пришедшая с сервера, может сама скомандовать приложению открыть любой адрес в браузере и даже подставить к нему свои служебные пометки — для этого во встроенном окне специально оставлен канал связи с названиями `AndroidMainInterface` и `AndroidMainFunctionV1`. Так же ведут себя и рекламные блоки: нажатие на такой блок сначала отмечается на сервере как «клик», а затем открывает полученный адрес во внешнем браузере. Если же сервер ответил «страницы нет» либо язык телефона не подошёл, ничего не открывается и человеку просто остаётся обычное приложение.